

IT-Sicherheitsrichtlinie

1. Zweck und Geltungsbereich

Diese Richtlinie legt die verbindlichen Mindestanforderungen an die Informationssicherheit bei der Aurelia Maschinenbau GmbH fest. Sie gilt für alle Mitarbeitenden, externen Dienstleister und Praktikanten mit Zugang zu Unternehmenssystemen.

2. Passwörter und Authentifizierung

Anforderung	Vorgabe
Mindestlänge Passwort	14 Zeichen
Komplexität	mindestens drei der vier Zeichenklassen (Groß-, Kleinbuchstaben, Ziffern, Sonderzeichen)
Passwortwechsel	nur bei Verdacht auf Kompromittierung (kein turnusmäßiger Wechsel)
Multi-Faktor-Authentifizierung (MFA)	verpflichtend für alle Konten, insbesondere VPN, Microsoft 365, SAP
Passwort-Manager	Bitwarden (Unternehmenslizenz) ist zu verwenden
Wiederverwendung	Passwörter dürfen nicht für private Dienste verwendet werden

Administrative Konten sind personengebunden und dürfen nicht für tägliche Arbeit genutzt werden.

3. Geräte und Arbeitsplatz

- Bildschirmsperre automatisch nach **10 Minuten** Inaktivität; beim Verlassen des Arbeitsplatzes ist manuell zu sperren (Windows + L).
- Festplattenverschlüsselung (BitLocker) ist auf allen mobilen Geräten aktiviert und darf nicht deaktiviert werden.
- USB-Speichermedien sind gesperrt. Ausnahmen nur mit freigegebenen, verschlüsselten Datenträgern der IT (Kensington-Serie).
- Software darf ausschließlich aus dem Unternehmens-Softwareportal installiert werden (siehe Software-Freigabeliste).

4. Klassifizierung von Informationen

Klasse	Beispiele	Umgang
Öffentlich	Produktprospekte, Pressemitteilungen	keine Einschränkung
Intern	Prozessbeschreibungen, Organigramme	nur innerhalb des Unternehmens; Weitergabe an Partner nur mit NDA
Vertraulich	Kundenverträge, Gehaltsdaten, Konstruktionszeichnungen	Zugriff nur für berechtigte Personen; Verschlüsselung bei Versand; kein Ausdruck im Homeoffice
Streng vertraulich	M&A-Unterlagen, Quellcode der Steuerungssoftware	ausschließlich benannter Personenkreis; Speicherung nur in freigegebenen Systemen; Protokollierung jedes Zugriffs

5. E-Mail und Phishing

Verdächtige E-Mails sind über den Button "Phishing melden" in Outlook oder an **security@aurelia-maschinenbau.example** zu melden. Anhänge unbekannter Absender dürfen nicht geöffnet werden. Die IT führt quartalsweise Phishing-Simulationen durch.

6. Umgang mit KI-Diensten

Öffentliche KI-Dienste (z. B. ChatGPT, Gemini) dürfen nur mit Informationen der Klasse "Öffentlich" genutzt werden. Für interne Daten steht der unternehmensinterne KI-Assistent **AURA** zur Verfügung, der ausschließlich freigegebene Dokumente verwendet.

7. Sicherheitsvorfälle

Jeder Verdacht auf einen Sicherheitsvorfall (Verlust eines Geräts, ungewöhnliches Systemverhalten, versehentliche Datenweitergabe) ist **unverzüglich, spätestens innerhalb von 2 Stunden**, an den IT-Servicedesk (Durchwahl -4444) zu melden. Details regelt der Incident-Response-Prozess.

8. Verstöße

Verstöße gegen diese Richtlinie können arbeitsrechtliche Konsequenzen haben. Bei Unsicherheiten ist der Informationssicherheitsbeauftragte (ISB) zu kontaktieren.